

Table of Contents

Cisco Secure Workload — TISAX / VDA ISA

Reference Design | Automotive Suppliers and OEM Partners

Version: 1.0

Framework: TISAX® (Trusted Information Security Assessment Exchange), assessment of the VDA ISA (Information Security Assessment) catalogue published by the German Association of the Automotive Industry (VDA)

Use Case: Information security level evidence, prototype-protection segmentation, data-protection segmentation, supplier readiness for ENX/TISAX assessment

Framework version note. TISAX is the assessment label operated by the ENX Association; VDA ISA is the underlying control catalogue. VDA ISA has multiple published versions (5.x at the time of writing) and the assessment objectives (AL 1 / AL 2 / AL 3 / AL High / AL Very High) determine which catalogues apply (Information Security, Prototype Protection, Data Protection). Topic area names (e.g. "Asset Management", "IT Security / Cyber Security", "Identity and Access Management", "Cryptography", "Operations Security", "Communications Security", "System Acquisition, Development and Maintenance", "Supplier Relationships", "Incident Management", "Business Continuity Management", "Compliance") are stable across recent versions; specific control numbering is **not** stable across versions. This reference design references **topic areas by name**, not specific VDA ISA control numbers — validate the control numbering against your assessment's catalogue version.

CSW UI navigation note. Cisco does not yet publish TISAX-specific CSW UI navigation; framework-specific paths are on the product roadmap. This reference design describes CSW *capabilities* and the *evidence artifacts* they produce.

Reader's Guide

Who this is for. Automotive suppliers and OEM development partners preparing for, maintaining, or renewing a TISAX assessment; CISO function, information security officer, and the team owning the VDA ISA self-assessment (the "ISA workbook") and the ENX assessor engagement.

Questions this reference design helps you answer:

- *Can I produce technology asset and information-asset evidence to support the Asset Management topic area?*

- *Can I show network segmentation between prototype-handling environments and the general IT estate to support Prototype Protection?*
- *Can I evidence access privileges and segmentation between processing environments handling personal or special-category data to support Data Protection?*
- *Can I produce continuous control evidence rather than point-in-time samples for IT Security / Cyber Security and Operations Security topics?*
- *Can I produce forensic timeline evidence for the Incident Management topic in the event of an assessment-relevant incident?*

What you'll need. Information asset register, prototype project / development project register (if Prototype Protection is in scope), data protection register (where applicable), VDA ISA self-assessment workbook draft, ENX assessment objective(s) and assessment scope ID, CMDB or cloud asset inventory, and supplier register.

Where to start. Sections 1–4 if you are scoping a deployment; 5–7 if you are designing and simulating policy; 9–10 if you are preparing the ISA workbook evidence or the on-site assessment within the next quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated

- ❑ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ❑ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ❑ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ❑ SIEM integration verified (sample events)
- ❑ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Prototype/confidential engineering workload segmentation
- Supplier/customer egress evidence
- Assessment-ready export pack

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

TISAX is not a control standard — it is a sharing mechanism operated by the ENX Association for VDA ISA assessment results across the automotive industry. The underlying VDA ISA catalogue is structured by topic areas with maturity-level scoring per control. The assessment objectives (e.g. AL 2, AL 3, AL High, AL Very High) determine which controls are in scope.

CSW supports **technical evidence** for the network-, workload-, and reachability-related topics of the VDA ISA catalogue: asset management at the workload layer, communications security, operations security, incident management forensic inputs, and elements of identity and access management at the workload-to-workload layer. CSW does **not** replace organisational policy, training, supplier assurance, physical security, prototype physical handling, identity lifecycle, cryptography assurance, or the assessment itself.

VDA ISA Topic Areas and CSW Relevance (topic names; not version-specific control IDs)

VDA ISA topic area	CSW relevance
Information Security Policies &	Out of scope (governance)

VDA ISA topic area	CSW relevance
Organisation	
Asset Management	Workload inventory; scope and label evidence; reachability
Identity and Access Management	Workload-to-workload allowlist (complements identity-layer IAM)
Cryptography	Plaintext-protocol detection on regulated paths (detection only)
Operations Security	Continuous workload monitoring; vulnerability + reachability data
Communications Security	Workload-level segmentation; ADM-derived allowlist; policy enforcement
System Acquisition, Development, Maintenance	Out of scope for code-level controls; CSW shows reachability of dev / build environments
Supplier Relationships	Outbound flow visibility to supplier endpoints
Information Security Incident Management	Forensic flow + process telemetry
Business Continuity Management	Approved flow baseline as one input to recoverability evidence
Compliance	Periodic evidence pack inputs
Prototype Protection (when in scope)	Workload-level isolation of prototype environments; reachability evidence
Data Protection (when in scope)	Workload-level isolation of personal-data environments; reachability evidence

2. Pre-Deployment Checklist

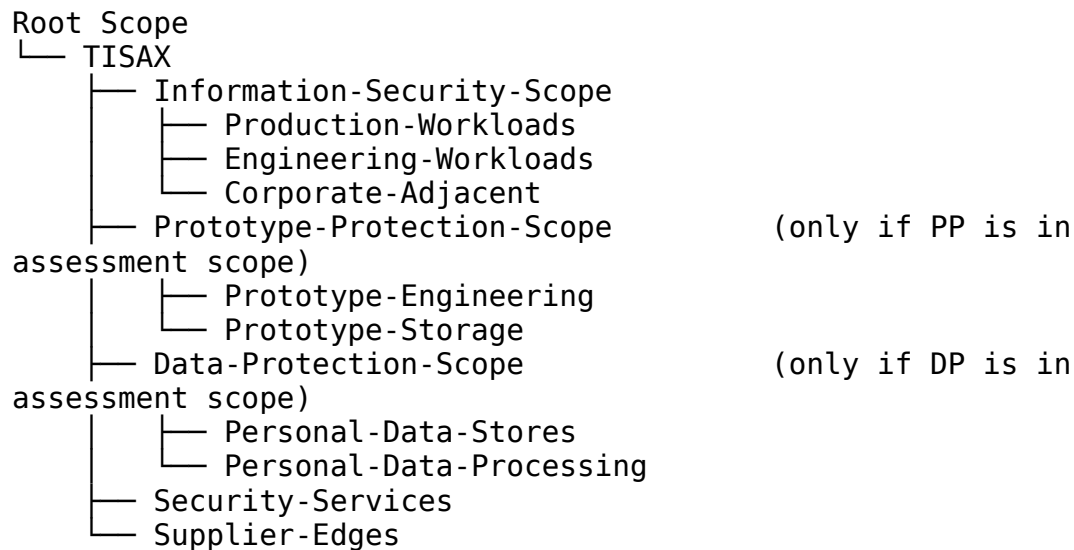
- ☐ CSW cluster provisioned
- ☐ Sensor compatibility verified for relevant Linux / Windows workloads
- ☐ Cloud accounts connected via CSW cloud connectors where in-scope workloads run in cloud
- ☐ TISAX assessment scope ID(s), assessment objective(s), and assessment level confirmed
- ☐ VDA ISA workbook version confirmed
- ☐ Information asset register, prototype project register, and data protection register available
- ☐ Stakeholders identified: CISO, IS Officer, ISA workbook owner, internal audit
- ☐ Evidence retention agreed with the IS Officer and assessor expectations

3. Phase 1 — Sensor & Connector Deployment (Days 1–5)

- Install software sensors on representative workloads in monitoring mode
 - Connect cloud accounts as read-only CSW cloud connectors for in-scope cloud workloads
 - Apply Day-1 labels: application, env, data_class, prototype, assessment_objective, owner, compliance=tisax
 - Maintain a cannot-instrument register for managed SaaS and appliances
 - Retain Phase-1 sensor inventory baseline
-

4. Phase 2 — Scope & Information Asset Mapping (Days 6–10)

4.1 Suggested Scope Architecture



4.2 Inventory Filters

Filter: Personal-Data-Stores

- Tag: data_class = personal | special-category
- Listening port: 1521, 3306, 5432, 1433, 27017

Filter: Prototype-Engineering-Candidates

- Tag: prototype = true | confidential-project
- Hostname / application pattern matches engineering / PLM systems

Filter: Supplier-Edges

- Destination outside on-prem and cloud allow-lists
- Tag: managed_by = supplier

4.3 Labeling Strategy

Label key	Example values	Why it matters for VDA ISA
data_class	personal, special-category, prototype, internal, public	Anchors Information Security, Prototype Protection, Data Protection topic areas
prototype	true, false	Marks workloads in Prototype Protection scope (if applicable)
assessment_objective	AL2, AL3, AL-High, AL-Very-High	Aligns evidence stringency to the assessment objective
application		Connects workloads to information assets
env	production, integration, dev, test	Environment segregation evidence
owner		Accountability
compliance	tisax	Filters CSW evidence to the TISAX scope
.		

5. Phase 3 — Application Dependency Mapping (Days 11–21)

Run ADM for each scope across a 2-week-minimum window. Document, per cluster:

Question	VDA ISA topic
Which workloads receive connections from outside the assessment scope?	Communications Security
Are flows into personal-data environments minimised and approved?	Data Protection
Are flows into prototype environments minimised and approved?	Prototype Protection
Are database connections encrypted?	Cryptography (detection input)
Which workloads reach supplier endpoints?	Supplier Relationships
Are there unexpected lateral connections inside engineering environments?	Operations Security / Incident Management

Use ADM clusters to confirm or correct `data_class`, `prototype`, and `assessment_objective` labels with information asset owners.

6. Phase 4 — Policy Development (Days 22–35)

6.1 TISAX-Aligned Policy Framework

Absolute policies (Prototype Protection example):

DENY Any → Prototype-Protection-Scope
(default deny inbound)
DENY Prototype-Protection → Internet
(no direct internet egress)
DENY Corporate-Adjacent → Prototype-Protection
(admin only via approved jump paths)

Allowlist policies (least privilege):

ALLOW Prototype-Engineering → Prototype-Storage
tcp/<approved-port>
ALLOW Personal-Data-Processing → Personal-Data-Stores
tcp/<db-port-tls>
ALLOW Production-Workloads → Security-Services
tcp/443
ALLOW Jump-Hosts → In-Scope-Workloads
tcp/22, tcp/3389

Catch-all:

LOG Any → Prototype-Protection-Scope
(unmatched inbound)
LOG Personal-Data-Stores → Any
(unmatched outbound)

6.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate the candidate policy
2	Enforcement (high-confidence rules only)	1 week	Enforce obvious deny rules
3	Full Enforcement	Ongoing	Workload allowlist enforced; monthly exception review

Workspace snapshots = Communications Security / Operations Security control-implementation evidence.

7. Phase 5 — Topic Mapping with CSW Evidence

VDA ISA topic area	What CSW produces	How to use it
Asset Management	Workload inventory; scope + label export	Asset and classification evidence at the workload layer
Identity and Access Management	Policy workspace and enforcement / violation log	Workload-to-workload privilege evidence (complements identity layer)
Cryptography	Plaintext-flow detection on regulated paths	Detection input only
Operations Security	Continuous monitoring; vulnerability + reachability	Operations control evidence
Communications Security	Policy workspace; ADM-derived allowlist; observed flows	Segmentation evidence
Supplier Relationships	Outbound flow summary to supplier endpoints	Reconciliation against the supplier register
Information Security Incident Management	Flow + process search across the incident window	Forensic timeline
Prototype Protection (if in scope)	Isolation evidence for Prototype-Protection scope	Reachability into prototype environment is constrained
Data Protection (if in scope)	Isolation evidence for Personal-Data scope	Reachability into personal-data environment is constrained
Compliance	Periodic evidence pack (Section 10.1)	Assessor work-paper input

8. Phase 6 — Vulnerability & Risk Management

Use reachability-weighted CVE data:

Priority 1: Critical CVE on Prototype-Protection-Scope with inbound reachability

Priority 2: Critical CVE on Personal-Data-Stores with inbound reachability

Priority 3: Critical CVE on supporting workloads with reach into either of the above

Document compensating controls in the policy workspace exception register; this register is itself evidence for the Operations Security / Information Security topic.

9. Phase 7 — Monitoring & Alerting

Alert	Trigger	VDA ISA topic
Unauthorised reach to Prototype-Protection	Any unapproved source → PP scope	Prototype Protection
Unauthorised reach to Personal-Data-Stores	Any unapproved source → PD scope	Data Protection
Plaintext on regulated paths	HTTP / unencrypted DB protocol from PP or PD scopes	Cryptography (detection)
Lateral movement inside engineering scope	New east-west flow outside baseline	Operations Security
Supplier egress anomaly	New egress to a non-listed supplier endpoint	Supplier Relationships
Policy violation	Enforced policy block triggered	Communications Security
Sensor offline	Agent stops reporting	Evidence integrity

9.2 Forensic Telemetry

Retain per incident:

- Flow log scoped to affected workload(s) and time window
 - Process search output
 - Policy workspace state at the time of the incident
 - Vulnerability snapshot for the affected workload(s)
 - Supplier-edge reach summary if relevant
-

10. Reporting & Evidence Collection

10.1 Evidence per Assessment / Surveillance Cycle (quarterly recommended; annually for assessment renewal)

Evidence item	CSW source area	VDA ISA topic
Workload inventory	Inventory export	Asset Management
Scope + label membership	Scope membership export	Asset Management

Evidence item	CSW source area	VDA ISA topic
Approved vs. observed flows	ADM workspace export	Communications Security
Policy workspace snapshot	Policy workspace export	Communications Security / IAM
Policy enforcement / violations	Policy analysis output	Operations Security
Vulnerability + reachability	Vulnerability report scoped to TISAX	Operations Security
Supplier egress summary	Flow search filtered to supplier endpoints	Supplier Relationships
Incident timeline sample	Flow + process search	Incident Management
Prototype-Protection isolation evidence	Inbound/outbound reach summary to PP scope	Prototype Protection
Data-Protection isolation evidence	Inbound/outbound reach summary to PD scope	Data Protection
Exception register	Policy workspace exceptions list	Operations Security

10.2 Ongoing Compliance Posture

- **Monthly:** scope / inventory hygiene; supplier egress reconciliation
- **Quarterly:** policy workspace review; refresh evidence pack 10.1
- **Annually / per surveillance:** refresh the VDA ISA self-assessment evidence references
- **Continuously:** policy drift detection; ADM re-run every 90 days

11. Common Pitfalls

Pitfall	Mitigation
Citing specific VDA ISA control numbers without confirming the catalogue version	Reference topic areas by name; pin specific control numbering only after confirming the workbook version
Treating TISAX as a single control standard	TISAX is the assessment label; the catalogues are Information Security, Prototype Protection, Data Protection
Prototype Protection assumed in scope when it is not on the assessment objective	Confirm assessment objectives in the ENX portal; map scope accordingly
prototype and data_class labels missing	Reconcile project register ↔ CSW labels at the start of each surveillance window
Encryption assumed by port	Confirm by process + observed

Pitfall	Mitigation
Supplier egress in internal scope	handshake, not by TCP port Maintain supplier register; ensure CSW labels mirror it

Related Frameworks in This Repository

- [ISO/IEC 27001:2022](#) — VDA ISA topic structure overlaps with ISO 27001 Annex A
- [GDPR](#) — relevant when Data Protection is in TISAX scope
- [NIST SP 800-53 Rev 5](#) — useful technical control reference

Document prepared for Cisco automotive-sector engagements. Replace [Customer Name] and any bracketed fields before customer delivery. Validate VDA ISA topic and control numbering against the catalogue version applicable to your TISAX assessment scope and objectives.